

Guía metodológica de la Encuesta Nacional SOAR

1. Objetivo general

La encuesta busca medir el grado de adopción, la calidad y el impacto de las capacidades de orquestación, automatización y respuesta (SOAR) en organizaciones españolas, con especial atención a entidades sujetas a NIS2 y ENS.

Su propósito último es disponer de datos comparables que permitan construir indicadores agregados (tiempos, coberturas, calidades, impacto económico) y orientar políticas públicas, inversiones empresariales y hojas de ruta de ciberseguridad.

2. Población objetivo y unidades de análisis

- Unidad de análisis primaria: organización (empresa, organismo público, entidad sujeta o no sujeta a NIS2/ENS).
- Respondente ideal: CISO, responsable de SOC, responsable de seguridad de la información, continuidad de negocio o equivalente.
- Cobertura sectorial: sectores esenciales (energía, transporte, banca, sanidad, agua, digital, etc.), administraciones públicas y sectores relevantes adicionales (industria, educación, I+D).

Se sugiere una **estratificación** por:

- Sector (NIS2 y otros).
- Tamaño (empleados).
- Naturaleza (público / privado).

3. Enfoque de diseño del cuestionario

El modelo de encuesta se ha construido a partir de:

- Recomendaciones de NIST SP 800-61 rev.3 en materia de indicadores de respuesta a incidentes.
- Guías de ENISA para CSIRT/SOC y marcos de madurez.
- Datos de incidentes gestionados por CERT nacionales (p. ej., INCIBE-CERT).
- Prácticas de mercado en métricas de SOC y SOAR (MTTD, MTTR, cobertura de automatización, falsos positivos, etc.).

El cuestionario:

- Combina **preguntas cerradas** con opciones claras para facilitar el análisis estadístico.
- Introduce **preguntas de percepción** que permiten contextualizar la lectura de los datos.
- Incluye **campos abiertos** para capturar matices y casos singulares.

4. Dimensiones analíticas

Las preguntas se agrupan en las siguientes dimensiones:

1. Información general y contexto regulatorio (P0–4, 29).
2. Gobierno y estrategia SOAR (P5–8, 37–39).
3. Modelo operativo de SOC y cobertura de automatización (P9–13, 25–28).
4. Métricas de tiempo (MTTD, MTTC, MTTR) (P14–18).
5. Métricas de calidad (falsos positivos, re-aperturas, rollback) (P19–24).
6. Regulación, cumplimiento y notificación (P29–32).
7. Impacto económico y ROI (P33–36).
8. Madurez, barreras y futuro (incluida IA) (P37–40).
9. Comentarios cualitativos (P41–42).

Cada dimensión permite análisis comparativos por sector, tamaño y naturaleza de la organización.

5. Tipo de escala y tratamiento de datos

La mayor parte de preguntas utiliza **escalas ordinales** (rangos de tiempos, porcentajes, niveles de madurez) o **clasificaciones nominales** (sector, modelo de SOC).

Para análisis cuantitativos se proponen las siguientes aproximaciones:

- Para rangos de tiempo (MTTD, MTTR) y porcentaje de cobertura, asignar valores numéricos centrales del rango (por ejemplo, 15–60 min → 37,5 min) o puntos representativos acordados.
- Para niveles de madurez, definir una escala 1–5 (Inicial–Líder).
- Para percepciones (valor de SOAR, impacto en tiempos), asignar puntuaciones ordenadas (p. ej. de “empeoramiento” a “disminución > 50 %”).

Cuando se disponga de suficientes respuestas, se podrán calcular:

- Promedios y medianas por sector / tamaño.
- Distribuciones de frecuencia.
- Correlaciones simples entre madurez / cobertura de automatización y tiempos / percepción de impacto.

6. Indicador Global de Madurez (IGM)

La encuesta está pensada para poder construir un **Indicador Global de Madurez (IGM)** SOAR por organización, a partir de:

- Eje Gobierno y estrategia: P5, P7, P8, P25.
- Eje Operación y cobertura: P9–13, P26–28.
- Eje Métricas y calidad: P14–24.
- Eje Regulación y reporting: P29–32.
- Eje Impacto y ROI: P33–36.
- Eje Futuro e innovación: P37–40.

Cada eje se evalúa en una escala normalizada (0–100), y el IGM global se obtiene como combinación ponderada de los ejes (por ejemplo, ponderación uniforme, o mayor peso para operación y métricas).

La plantilla de Excel propuesta (documento e) describe una implementación posible.

7. Medición del ROI de SOAR

El cuestionario no pretende capturar valores económicos exactos, sino preparar el terreno para:

- Estimaciones de reducción de tiempos pre- y post-SOAR (P18).
- Grado de formalización del cálculo de costes de incidentes (P33–34).
- Existencia y calidad percibida de modelos de ROI (P35–36).

Estos datos permiten, combinados con parámetros de coste medio de incidentes (externos o internos), estimar rangos de ROI y construir escenarios de sensibilidad.

8. Aspectos éticos y de confidencialidad

Se recomienda:

- Garantizar el anonimato de las respuestas en los informes públicos.
- Firmar acuerdos de confidencialidad con las organizaciones participantes, especialmente cuando se recaben datos sobre tiempos de respuesta, costes o cumplimiento regulatorio.
- Asegurar que los resultados se presenten de forma agregada por sector / tamaño para evitar identificaciones accidentales.

9. Procedimiento de recogida

- Modalidad: cuestionario online (preferiblemente), con posibilidad de entrevistas semiestructuradas para clarificar extremos en organizaciones clave.
- Duración estimada: 20–30 minutos.
- Periodo de campo sugerido: 8–12 semanas, con recordatorios escalonados.
- Tasa de respuesta objetivo: al menos 30–40 % en sectores prioritarios.

Superada la fase de recogida, se recomienda:

10. Limpieza de datos (detección de inconsistencias, respuestas incompletas).
11. Construcción de los ejes de madurez e IGM.
12. Análisis comparativos (sector, tamaño, naturaleza).
13. Elaboración de un informe ejecutivo y, en su caso, informes personalizados para entidades que lo soliciten.

10. Limitaciones y sesgos

Entre las limitaciones previsibles:

- Sesgo de autoselección: es probable que respondan más las organizaciones con cierta sensibilidad en ciberseguridad.
- Sesgo de deseabilidad: tendencia a presentar una imagen “mejorada” de las capacidades reales de automatización y métricas.
- Diferencias de interpretación: términos como “automatización”, “playbook” o incluso “incidente crítico” pueden variar entre organizaciones.

La guía metodológica sugiere mitigar estos sesgos mediante:

- Definiciones claras al inicio del cuestionario.
- Notas explicativas junto a las preguntas críticas.
- Posibilidad de entrevistas de contraste con una submuestra de organizaciones.

11. Uso de los resultados

Los resultados de la encuesta pueden alimentar:

- La definición de políticas públicas y líneas de apoyo a la automatización y SOAR.
- La actualización de marcos nacionales de ciberseguridad y continuidad de negocio.
- La comparación con métricas europeas y globales.
- La elaboración de benchmarks sectoriales para que las organizaciones se posicionen frente a pares.

Idealmente, el ejercicio debería repetirse cada 2–3 años para observar tendencias e impactos reales de las estrategias de automatización.